Mandatory Access Control

Definition

Mandatory Access Control
Access to and operations on resources are determined by the security policy
- "owner" may not exist or not have power to set permissions against policy
- the security policy must be enforced despite subjects trying to subvert it

Definition

SECURITY MODEL : a design pattern for a specific security property or set of properties

Bell-La Padula (BLP) model : Protecting confidentiality

Subjects S and objects O associated to a level of confidentiality
Subjects access rights are defined by four attributes :

- **Execute :** the subject cannot see or modify the object, but can run it
- **Read :** the subject can only see the object but cannot modify it
- **Append :** the subject cannot read the object, but can add attach new content
- **Write :** the subject can see the object and add content or modify existing content

These access rights are defined in an access control matrix

Level function for objects : Classification
Objects are associated to a Security Level
(they have a label, and belong to one or more categories)

Key formulas

Security Level = (Classification, {set of categories})
- **Classification** – total order of labels (e.g., Unclassified, Confidential, Secret, Top Secret)
- **Categories** – compartments of objects with a common topic (e.g., Nuclear, NATO, Crypto)

Definition

DOMINANCE RELATIONSHIP
A security level (l_1, c_1) "dominates" (l_2, c_2) if and only if $l_1 \geq l_2$ and c_2 is a subset of c_1

Key idea

Three key properties
(a) Dominates is transitive.
(b) Top and bottom elements.
(c) Only partial order

Level function for subjects : Clearance level

- **Clearance** – maximum security level a subject has been assigned : clearance level(S_i)
- **Current security level** – subjects can operate at lower security levels : current-level(S_i)

Definition

SIMPLE SECURITY PROPERTY (SS-PROPERTY)
If (subject, object, r) is a current access, then level(subject) dominates level(object)

Definition

STAR PROPERTY (*-PROPERTY)
if a subject has simultaneous "observe" (r,w) access to O_1 and "alter" (a,w) access to O_2 then level(O_2) dominates level(O_1)

Definition

DISCRETIONARY PROPERTY (DS-PROPERTY)
if an access (subject, object, action) takes place it must be in the access control matrix

BLP : Basic Security Theorem

Key idea

BASIC SECURITY THEOREM
if all state transitions are security preserving, and the initial state is secure, then every subsequent state is secure regardless of the inputs

If for any individual access :
(1) the ss-property is preserved
(2) the *-property is preserved
(3) the ds-property is preserved
… then for any sequential composition security holds!

Definition

COVERT CHANNEL
any channel that allows information flows contrary to the security policy

Definition

DECLASSIFICATION
remove classification label

The BIBA model for integrity

Key idea

Two key rules (strict)
- **simple integrity (no read-down) :** protects higher integrity principals from being corrupted by lower integrity level data
- ***-integrity (no write-up) :** prevents lower integrity principals from corrupting high integrity data

Low-water-mark policy for subjects

- Subjects start processes at their highest integrity level.
- When accessing an object, its current level is lowered to the lowest of the two : current-level(s) and level(o)

Temporary downgrade for the session

- Example : mitigate impact of a network Trojan
- Hard to avoid label creep

Definition

SANITIZATION
Process of taking objects with “low” integrity and “lifting them” to “high integrity”

Key idea

PRINCIPLE 2 : FAIL-SAFE DEFAULT
“Base access decisions on permission rather than exclusion” [SS75]

Chinese Wall model : Access rules

Key idea

A subject can read an object (for either read or write) if the access does not allow an information flow between items with labels in the same conflict set